

Risk_ID	Asset
---------	-------

GOVERNANCE(GOV)	
-----------------	--

GOV-01	Vendor Management Program
GOV-02	Board Oversight

COMPLIANCE(CMP)	
-----------------	--

CMP-01	Payment Card Systems
CMP-02	Customer Data Warehouse
CMP-03	Customer Relationship Management (CRM) Platform

OPERATIONS(OPS)	
-----------------	--

OPS-01	Core Banking System
OPS-02	Remote Work VPN

SECURITY(SEC)	
---------------	--

SEC-01	Corporate Email
SEC-02	Cloud IAM Portal
SEC-03	Third-Party Payment API

Scenario	Category	Likelihood	Impact	Status
----------	----------	------------	--------	--------

Lack of third-party risk assessments for fintech partners	GOV	Medium	High	Open
Inadequate cyber-risk reporting to board	GOV	Low	Medium	Open

Non-compliance with PCI DSS 12.10 (incident response)	CMP	Medium	High	Open
Failure to mask PII in analytics environment	CMP	High	High	Open
SaaS CRM vendor breach exposing customer data	CMP	Medium	High	Open

Unplanned outage due to storage subsystem failure	OPS	Low	High	Mitigated
VPN concentrator overload causing downtime	OPS	High	Medium	Accepted

Credential-phishing campaign compromise	SEC	High	High	Open
Privilege escalation via misconfigured roles	SEC	Medium	Critical	Open
API key leakage from contractor repo	SEC	Low	High	Mitigated

Lambda_Min	Lambda_Mode	Lambda_Max	Loss_Min	Loss_Mode	Loss_Max
------------	-------------	------------	----------	-----------	----------

0.3	0.5	0.8	150000	350000	750000
0.2	0.3	0.6	100000	200000	400000

0.4	0.6	0.9	250000	600000	1200000
0.5	0.7	1	300000	800000	1500000
0.3	0.4	0.8	300000	900000	2000000

0.2	0.3	0.5	200000	400000	800000
0.6	0.8	1	100000	200000	400000

0.5	0.8	1	200000	500000	1000000
0.3	0.5	0.8	500000	1000000	2000000
0.2	0.3	0.5	150000	400000	900000

Owner	Notes
-------	-------

Vendor Risk Manager	Vendor inventory incomplete; assessment schedule drafted
CISO	Quarterly metrics not yet aligned to NIST CSF

Compliance Officer	PCI DSS gap found in IR testing documentation
Data Governance Lead	Sensitive data occasionally exposed in dev copies
Data Governance / CISO	SOC 2 Type II pending; overprovisioned access discovered

Infrastructure Manager	Redundant SAN implemented; DR site tested semi-annually
Network Engineer	Capacity expansion deferred; bandwidth alerts configured

Security Analyst	MFA enforced; users targeted by smishing variant
Cloud Security Engineer	Role review incomplete; least privilege project ongoing
AppSec Engineer	Secrets scanning added; vendor contract updated

Risk Description	Regulatory Impact	Risk Rating
------------------	-------------------	-------------

Lack of third-party risk assessments for fintech partners	GLBA	High
Inadequate cyber-risk reporting to board	N/A	Medium

Non-compliance with PCI DSS 12.10	PCI DSS	High
Failure to mask PII in analytics environment	GLBA	Critical
Exposure of customer PII through a breach at the external CRM vendor, resulting in regulatory penalties, forced notifications, reputational damage, and customer attrition.	GLBA	High

Unplanned outage due to storage subsystem failure	N/A	High
VPN concentrator overload causing downtime	N/A	High

Credential-phishing campaign compromise	N/A	Critical
Privilege escalation via misconfigured roles	SOC 2	Critical
API key leakage from contractor repo	PCI DSS	High

Mitigation/Control

TPEM tool procurement under review; risk tiering framework pending
--

Dashboard redesign planned; risk appetite statement draft Q2
--

IR playbook update and annual test scheduled
--

Data-masking controls being deployed; data-loss prevention tuning

Vendor SOC 2 Type II review scheduled; API access reduced to least privilege; encryption validation in progress; contract updated with mandatory breach notification timelines.

Full DR validated; continuous replication monitored

Risk accepted until budget approval for redundant appliance

Enhanced mail filtering; user awareness reinforcement

RBAC review; automated policy linter deployment

Git secret scans active; vendor compliance clause added
